

Capitolo 3

Work Package 3

I capitoli precedenti hanno formalizzato il modello di minaccia (WP1) e specificato la soluzione protocollare che intende soddisfarlo (WP2). Questo capitolo ne analizza la sicurezza con un obiettivo preciso: verificare che la soluzione di WP2 sia *ottimale* rispetto al modello di WP1, ovvero che non esistano modifiche semplici al protocollo capaci di rafforzare una proprietà di sicurezza senza al contempo indebolirne un'altra.

Il criterio adottato è dunque il seguente: per ciascuna proprietà suscettibile di rafforzamento si considera la modifica più immediata che la migliorerebbe e se ne tracciano le conseguenze sull'intero insieme delle proprietà. Si distinguono due esiti possibili:

- la modifica migliora una proprietà *a spese* di un'altra: si tratta allora di un **trade-off legittimo**, e la scelta operata in WP2 va difesa come bilanciamento consapevole, dichiarando esplicitamente quale proprietà si è scelto di privilegiare e perchè;
- la modifica migliora una proprietà *senza alcuna perdita*: in tal caso non si tratta di un trade-off, bensì di un difetto di progettazione di WP2, e la modifica viene incorporata nella soluzione.

Per facilitare la lettura e la disamina condotta, si presentano le diverse proprietà come paragrafi distinti, partendo dall'assimilazione delle ottimizzazioni prive di costo, per poi affrontare i compromessi ineliminabili tra Privacy, Integrità, Trasparenza e Disponibilità.

3.1 Ottimizzazioni Architettureali

3.1.1 Vincolo alla singola consultazione

L'analisi critica del protocollo ha evidenziato una potenziale vulnerabilità legata al ciclo di vita delle Autorizzazioni Anonime di Voto (AVP) su consultazioni elettorali multiple. Nella formulazione iniziale del WP2, l'IAP appone la propria firma digitale esclusivamente sul token pseudo-casuale generato dal client: $\sigma \leftarrow \text{Sign}_{sk_{IAP}}(R)$. In fase di sottomissione, il nodo VBR verifica l'autenticità di σ e l'unicità di R rispetto al registro della sessione corrente (R_{spent}). Tuttavia, poiché il VBR non ha accesso al plaintext del crittogramma C (che contiene l'identificativo della consultazione), non possiede gli strumenti crittografici per accertare a quale elezione l'AVP fosse originariamente destinata.

Questo espone l'architettura a una variante di **Replay Attack** su base multi-sessione: un avversario $\mathcal{A}_V$ potrebbe ottenere una AVP legittima in una elezione A (astenendosi dal votare) e riutilizzare la coppia $\langle R, \sigma \rangle$ in una elezione successiva B , allegando un nuovo crittogramma C' . Il VBR di B accetterebbe il pacchetto, poiché la firma dell'IAP risulterebbe matematicamente valida e il token R non figurerebbe tra quelli spesi nella sessione corrente.

Modifica implementata e assenza di Trade-off

Per neutralizzare questo vettore di attacco, si introduce una modifica a "costo zero" (free lunch) nel protocollo di accreditamento. Si richiede all'elettore di trasmettere all'IAP

non solo il token R , ma anche l'identificativo pubblico della consultazione ID_{elec} . L'IAP estende quindi il binding crittografico della propria firma includendo il contesto della sessione:

$$\sigma \leftarrow \text{Sign}_{sk_{IAP}}(R \parallel ID_{elec}) \quad (3.1)$$

In fase di sottomissione, il VBR (che è a conoscenza dell'elezione in corso) verificherà la firma sull'aggregato contestualizzato, rigettando deterministicamente eventuali Replay Attack provenienti da elezioni passate:

$$\text{Verify}(pk_{IAP}, R \parallel ID_{elec}, \sigma) = 1 \wedge R \notin R_{spent} \quad (3.2)$$

Valutazione dei Trade-off:

Questa modifica rappresenta un miglioramento netto, privo di controindicazioni.

- **Privacy e Unlinkability:** Nessuna perdita. LID_{elec} è un parametro pubblico e globale, identico per tutto il bacino elettorale. La sua inclusione nel payload firmato non aggiunge entropia identificativa al token R , preservando integralmente lo pseudo-anonimato dell'elettore.
- **Efficienza:** Il costo computazionale aggiuntivo di concatenare una stringa nota prima dell'operazione di firma è asintoticamente nullo.

In accordo con i criteri di validazione del WP3, questa ottimizzazione è stata considerata un *must-have* e, pertanto, si intende formalmente retro-incorporata nelle specifiche di WP2.

3.2 Analisi dei Trade-off Fondamentali

Il protocollo Aequitas è stato disegnato bilanciando proprietà strutturalmente in conflitto, ottimizzando la configurazione rispetto agli strumenti crittografici standard analizzati. Di seguito si discutono le scelte progettuali, motivando il sacrificio parziale di alcune garanzie a favore dei pilastri prioritari del sistema.

3.2.1 La possibilità di rivoto

Come discusso nel WP1, il protocollo di Aequitas **non supporta** la possibilità di modifica del voto. In tal senso, si specifica che tale proprietà consiste nel consentire la sostituzione del voto a urne aperte. Naturalmente, la possibilità di poter ri-votare in uno schema elettorale come quello descritto nel presente protocollo consente di mitigare la coercizione istantanea, in quanto un elettore può votare sotto minaccia e, in un secondo momento, cambiare la preferenza di voto. Tuttavia, in Aequitas questo beneficio è stato considerato trascurabile perchè su un registro pubblico la revoca non è una cancellazione, ma richiede meccanismi crittografici di **invalidazione** che esulano dal perimetro del corso. La contromisura è inoltre auto-contraddittoria: la ri-votazione dovrebbe permettere di sovrascrivere *in segreto* un voto estorto, ma se la sovrascrittura è pubblicamente verificabile il coercitore la osserva e la difesa si annulla. Si conclude che l'inseguimento di tale obiettivo si arresta dinanzi al *trade-off* tra verificabilità del voto e rischio di coercizione.

3.2.2 Il Binding Crittografico sull'Autorizzazione

Un'analisi rigorosa della fase di sottomissione solleva una criticità teorica: la firma dell'IAP (σ) copre esclusivamente il token R (e l' ID_{elec}), ma non il crittogramma della preferenza C .

Una potenziale modifica migliorativa consisterebbe nel vincolare l'intera scheda all'autorizzazione, imponendo all'IAP di calcolare $\sigma \leftarrow \text{Sign}_{sk_{IAP}}(R \parallel C)$. Questo creerebbe un *binding* crittografico inscindibile, rendendo matematicamente impossibile per chiunque (incluso un VBR malizioso) alterare o sostituire C senza invalidare la firma dell'IAP, elevando l'integrità del sistema.

Ciononostante, questa modifica è stata categoricamente scartata in quanto introdurrebbe un *trade-off* inaccettabile a danno dell'anonimato (Unlinkability). Affinché l'IAP possa firmare l'aggregato $(R \parallel C)$, l'elettore dovrebbe trasmettere il crittogramma all'Identity Provider durante la fase di accreditamento. Poiché l'IAP accerta l'identità reale del votante tramite SPID, verrebbe a conoscenza della relazione univoca tra l'identità anagrafica e il crittogramma C . Al termine dello scrutinio, la decifratura universale renderebbe pubblica la relazione $C \leftrightarrow v$ (dove v è la preferenza in chiaro). L'IAP potrebbe quindi collassare la catena deduttiva (Identità $\rightarrow C \rightarrow v$), distruggendo totalmente il segreto elettorale.

Per risolvere questo conflitto e ottenere il binding su C mantenendo l'IAP all'oscuro del suo contenuto, sarebbe necessario ricorrere a primitive crittografiche avanzate. Essendo tali strumenti al di fuori dello spettro crittografico standard trattato, il protocollo accetta la separazione tra autorizzazione (R) e payload (C) come vincolo di design ineliminabile. L'integrità del crittogramma C viene pertanto delegata non alla firma dell'IAP, bensì alla Verificabilità Individuale: è responsabilità dell'elettore accertarsi che l'impronta $H(C)$ iscritta a registro corrisponda a quella generata localmente dal proprio client.

3.2.3 Privacy Assoluta vs. Verificabilità Universale

Il cuore architetturale del protocollo Aequitas si fonda sulla scelta del meccanismo di scrutinio. La soluzione implementata nel WP2 prevede uno **scrutinio pubblico**: l'ambiente isolato, una volta ricostruita la chiave privata d , decifra tutti i crittogrammi e pubblica sul registro VBR le pre-immagini RSA (m'_i). Questo approccio garantisce in modo assoluto la Verificabilità Universale (Proprietà 5): qualsiasi osservatore indipendente può validare l'intero spoglio ricalcolando la cifratura con la chiave pubblica e dell'elezione, verificando che $(m'_i)^e \equiv C_i \pmod{N}$.

Una modifica architetturale ovvia per massimizzare la Segretezza e l'Unlinkability (Proprietà 3 e 4) consisterebbe nell'adottare uno **scrutinio privato**. In questo scenario, la Tally Machine decifrerrebbe i voti internamente, aggregando i conteggi per candidato, e pubblicherebbe esclusivamente l'esito elettorale finale (i totali $\{n_k\}$), omettendo la pubblicazione delle schede in chiaro.

Valutazione dei Trade-off

L'adozione dello scrutinio privato comporterebbe i seguenti impatti:

- **Vantaggio (Privacy):** Omettendo le pre-immagini, la relazione esatta tra il token pseudonimo R_i e la preferenza in chiaro v_i non diverrebbe mai di dominio pubblico. Questo neutralizzerebbe completamente la minaccia di de-anonimizzazione post-spoglio ($\mathcal{G}_{A_{IAP}}^{link}$) operata da un eventuale IAP malizioso, poiché l'IAP (pur conoscendo il legame $CF \leftrightarrow R_i$) non avrebbe accesso al legame $R_i \leftrightarrow v_i$.

- **Svantaggio (Trasparenza):** Il sistema perderebbe interamente la Verificabilità Universale. La correttezza del risultato non sarebbe più supportata da prove matematiche ispezionabili, costringendo gli elettori a riporre una fiducia totale nell'onestà e nella non-compromissione dell'ambiente di calcolo della Tally Machine e dei Trustee.

Nel campo della crittografia elettorale, ottenere simultaneamente uno scrutinio privato e la verificabilità universale richiederebbe l'impiego di primitive crittografiche avanzate, concepite appositamente per dimostrare la correttezza di una computazione senza mai rivelarne gli input in chiaro.

Poiché lo studio e l'implementazione di tali strumenti esulano dal perimetro didattico del corso e dalle primitive standard a disposizione, Aequitas assume un *trade-off* netto e deliberato a favore della **trasparenza**. Il protocollo sceglie di sacrificare la segretezza algoritmica assoluta post-spoglio per garantire che la fiducia nel sistema derivi esclusivamente da prove matematiche (la verifica delle pre-immagini RSA) che chiunque può riprodurre e ispezionare. La protezione della privacy dell'elettore viene conseguentemente delegata allo pseudo-anonimato, basato sull'assunzione organizzativa e operativa che l'IAP operi in un dominio di sicurezza isolato dal VBR e applichi rigorosamente politiche di *no-log* per distruggere le coppie (CF, R_i) prima dell'apertura delle urne.

3.2.4 Parametrizzazione dello Schema a Soglia

L'architettura di Aequitas elimina il *Single Point of Failure* associato alla gestione della chiave privata dell'elezione (sk_{elec}) affidandosi allo schema di condivisione a soglia di Shamir. Questo costrutto richiede di configurare due parametri fondamentali: il numero totale dei fiduciari (n) e la soglia minima di ricostruzione (t).

Una potenziale modifica per innalzare il livello di sicurezza del sistema consisterebbe nell'aumentare la soglia t , avvicinandola o eguagliandola a n (es. configurazione 4 su 5, o 5 su 5).

Valutazione dei Trade-off

La variazione del parametro t impone un bilanciamento a somma zero tra due dei pilastri fondamentali della sicurezza informatica:

- **Vantaggio (Confidenzialità):** Innalzare t massimizza la robustezza del sistema contro le minacce di collusione attiva ($\mathcal{G}_{AFID}^{secret}$). Affinché i fiduciari possano decifrare le schede in anticipo violando il segreto elettorale, sarebbe necessaria la compromissione di un numero maggiore di nodi.
- **Svantaggio (Disponibilità - Availability):** L'aumento di t degrada in modo speculare la tolleranza ai guasti (Fault Tolerance) in fase di scrutinio. In una configurazione con t molto prossimo a n , l'indisponibilità temporanea, il guasto o il sabotaggio attivo (omissione) di un numero minimo di fiduciari pari a $n - t + 1$ comporterebbe l'impossibilità matematica di ricostruire il polinomio segreto. L'intero processo di spoglio subirebbe un'interruzione di servizio irreversibile, configurando una violazione catastrofica della Disponibilità.

Il protocollo Aequitas accetta l'impossibilità di massimizzare simultaneamente entrambe le proprietà. La scelta progettuale ricade pertanto su un *trade-off* operativo basato su una soglia di maggioranza qualificata (es. $t = 3$ per $n = 5$). Tale configurazione viene

considerata ottimale in quanto impone un costo significativo a un eventuale attaccante interno (che deve corrompere la maggioranza dei nodi fiduciari) pur garantendo la resilienza dello scrutinio a fronte di guasti o defezioni di una minoranza dell'infrastruttura.

3.2.5 Architettura del VBR

L'analisi del modello di minaccia relativo al registro pubblico (WP1) ha evidenziato che il VBR, essendo logicamente centralizzato, rappresenta un potenziale *Single Point of Failure* (SPOF) per quanto concerne la Disponibilità e un potenziale vettore per attacchi di omissione ($\mathcal{A}_{VBR}$). Sebbene l'impiego di strutture dati autenticate (Merkle Tree) garantisca in modo assoluto l'integrità dei dati salvati, rendendo impossibile per un VBR malizioso alterare i crittogrammi senza essere rilevato, la crittografia applicativa non può impedire a un server corrotto di rifiutare la ricezione di nuove schede o di andare offline. Una modifica architetturale drastica per eliminare questa vulnerabilità consisterebbe nel sostituire il database centralizzato del VBR con un registro distribuito basato su **Blockchain** (DLT), gestendo l'inserimento delle schede elettorali tramite *Smart Contract*.

Valutazione dei Trade-off

La transizione verso un'architettura Blockchain impone un bilanciamento estremo, noto in letteratura come il "Trilemma della Scalabilità":

- **Vantaggio (Resilienza assoluta alla Censura e Disponibilità):** La decentralizzazione del consenso tra migliaia di nodi indipendenti eliminerebbe totalmente lo SPOF. Nessuna singola entità (nemmeno un'Autorità Elettorale corrotta) avrebbe il potere di censurare una specifica transazione di voto o di bloccare l'infrastruttura, massimizzando l'Availability e la tolleranza ai guasti.
- **Svantaggio (Throughput, Latenza e Costi Computazionali):** Il raggiungimento di un consenso distribuito richiede tempi di elaborazione fisiologici e impone rigidi limiti al numero di transazioni processabili al secondo (Throughput). In uno scenario elettorale su scala nazionale, dove si registrano picchi di migliaia di voti al secondo, una Blockchain causerebbe latenze inaccettabili per l'utente finale, contravvenendo ai requisiti fondamentali di *usabilità* ed *efficienza* del sistema.

Il protocollo Aequitas rigetta pertanto la decentralizzazione assoluta in favore di un *trade-off* orientato all'efficienza e alla scalabilità. Si opta per il mantenimento di un VBR centralizzato dal punto di vista dell'infrastruttura di rete, ma "decentralizzato" nella fiducia logica, poiché sottoposto a Verificabilità Individuale e Universale. Il rischio residuo di censura viene accettato come limite architetturale, mitigato unicamente dalla trasparenza del processo: l'eventuale rifiuto sistematico delle connessioni da parte del VBR costituirebbe un'anomalia immediatamente evidente e denunciabile dalla collettività.